ISTQB® Certified Tester

Advanced Level — **Security Tester** (CT-SEC, Syllabus 2016)

CHAPTER 1

The Basis of Security Testing

Complete Study Guide

Chapter fact	Value
Syllabus sections covered	1.1 Security Risks · 1.2 Information Security Policies and Procedures · 1.3 Security Auditing and Its Role in Security Testing
Learning objectives	6 examinable (AS-1.1.1 – AS-1.3.1) · K2 = 3 · K4 = 3
Recommended teaching time	105 minutes — **8 points**, 4.6 points per teaching hour
Questions in the exam	**4 of 45 questions · 8 of 80 points.** K2 = 2 · K3 = 0 · **K4 = 2**. Guaranteed: **AS-1.2.1** (K2) and **AS-1.2.2** (K4). One K2 from AS-1.1.1/1.3.1; one K4 from AS-1.1.2/1.1.3
Exam format	45 questions · **80 points** · **120 minutes** (150 with the 25% non-native-language allowance) · pass mark 65% = **52 points** · K2 = 1 pt · K3 = 2 pts · K4 = 3 pts
Keywords	data privacy · ethical hacker · information security · penetration testing · risk assessment · risk exposure · risk mitigation · security attack · security audit · security policy · security procedure · security risk
Official sample-exam questions	**#1 – #4** (1 + 3 + 1 + 3 points)

Built exclusively from the ISTQB® Advanced Level Security Tester syllabus (2016), the official Sample Exam (questions and answers, GA March 2016) and the ISTQB® exam structure tables.

Study this single file to master Chapter 1.

Contents

Section 1 — Syllabus Explanation....4
Chapter framing — what makes security testing different....4
AS-1.1.1 (K2) — The Role of Risk Assessment in Security Testing....5
AS-1.1.2 (K4) — Asset Identification....5
AS-1.1.3 (K4) — Analysis of Risk Assessment Techniques....6
AS-1.2.1 (K2) — Understanding Security Policies and Procedures....7
AS-1.2.2 (K4) — Analysis of Security Policies and Procedures....9
AS-1.3.1 (K2) — Security Auditing and the Purpose of a Security Audit....10
§1.3.2 — Risk Identification, Assessment and Mitigation (supports AS-1.1.x and 1.3.1)....11
§1.3.3 — People, Process and Technology....13
Section 2 — Key Concepts....14
2.1 The storyline of Chapter 1....14
2.2 Risk and how it is measured....14
2.3 Why the risk assessment drives security testing....15
2.4 Policies, procedures and controls....17
2.5 Checking that it works: evaluation, audit and test....18
2.6 Fuzzy points clarified....20
2.7 Chapter 1 keyword glossary....21
Section 3 — Tables and Summaries....22
Section 4 — Demo Questions with Answers....24
Part A — The 4 official Chapter 1 questions....24
Part B — 18 additional syllabus-derived questions....25
Most Important Questions From This Chapter....30
Section 5 — Exam Tricks....31
5.1 Frequently tested topics (evidence-based)....31
5.2 Common distractors observed....31
5.3 Keyword recognition (map words → answers)....31
5.4 Typical traps....32
5.5 How to eliminate wrong answers....32
5.6 Scenario-solving shortcuts....32
5.7 Common candidate mistakes....33
5.8 Mnemonics that carry the whole chapter....33
5.9 Chapter 1 mind map....33
Section 6 — Revision Notes....34
6.1 One-page chapter summary....34
6.2 Key definitions to memorize....34
6.3 High-priority concepts (study first)....34
6.4 Last-minute revision sheet....34
6.5 Memorization checklist....35
6.6 Exam-day quick review....35

In Word, right-click the table of contents and choose "Update Field" → "Update entire table" to refresh the page numbers.

How to use this guide

Section 1 explains all six learning objectives in syllabus order — read it once, slowly. **Section 2** explains every key concept from the ground up — plain words, how it works, a worked example, the exam angle, and what it is easily confused with — and ends with the chapter's **fuzzy points clarified**. If the syllabus wording in Section 1 feels dense, read the matching Section 2 card first. **Section 3** holds the tables to reproduce from memory; **table 3.2 (behaviour → policy)** and **the risk matrix** pay directly. **Section 4** is the question bank — cover the green box, answer, then read the rationale even when you were right. **Section 5** converts that into exam tactics. **Section 6** is the revision sheet for the night before and the morning of the exam.

What makes Chapter 1 unusual: it reads like an introduction but **two of its four questions are 3-point K4 scenarios**. Those two items are **6 of the chapter's 8 points** — as much as six K2 questions elsewhere on the paper.

Two rules that decide those six points: first, **policy effectiveness is shown by security test results**, never by review alone — a policy can be in place, followed and still ineffective. Second, a security risk assessment must include **external stakeholders**, and when the stem is about **legal compliance** the stakeholder that matters is the **regulator who issues the guidelines**.

Suggested schedule: Day 1 — Section 1 (AS-1.1.x). Day 2 — Section 1 (AS-1.2.x and 1.3.1) and Section 3. Day 3 — Section 2 and Section 4 Part A. Day 4 — Section 4 Part B and Section 5. Day 5 onwards — redo the questions you missed and re-read Section 2's fuzzy points. Night before — Section 6.

Section 1 — Syllabus Explanation

Chapter 1, **The Basis of Security Testing**, carries **6 learning objectives** across three sub-chapters (1.1 Security Risks · 1.2 Information Security Policies and Procedures · 1.3 Security Auditing and Its Role in Security Testing). The ISTQB Exam Structure Table allocates **4 of the 45 questions** and **8 of the 80 points** to it. Recommended teaching time is **105 minutes**, which works out at **4.6 points per teaching hour** — roughly the paper average.

The chapter looks like a gentle introduction, but **half its questions are K4**. Two of the four questions are 3-point analysis items — one on analysing policies against test results (**AS-1.2.2**, guaranteed) and one drawn from the asset / risk-assessment pair (**AS-1.1.2 or AS-1.1.3**). Those two questions are **6 of the chapter's 8 points**. Get the K4 reasoning right and the chapter pays well; treat it as vocabulary and it does not.

LO ID	K	Objective (syllabus statement)	Qs	Pts
AS-1.1.1	K2	Understand the role of risk assessment in supplying information for security test planning and design and aligning security testing with business needs.	1 of 2†	1
AS-1.1.2	**K4**	Identify the significant assets to be protected, the value of each asset and the data required to assess the level of security needed for each asset.	1 of 2‡	3
AS-1.1.3	**K4**	Analyze the effective use of risk assessment techniques in a given situation to identify current and future security threats.	1 of 2‡	3
AS-1.2.1	K2	Understand the concept of security policies and procedures and how they are applied in information systems.	**1**	1
AS-1.2.2	**K4**	Analyze a given set of security policies and procedures along with security test results to determine effectiveness.	**1**	**3**
AS-1.3.1	K2	Understand the purpose of a security audit.	1 of 2†	1
Chapter 1 total	—	**K2 = 2 · K3 = 0 · K4 = 2**	**4**	**8**

*† One K2 question is drawn from AS-1.1.1 and AS-1.3.1 together. ‡ One K4 question is drawn from AS-1.1.2 and AS-1.1.3 together. In the official Sample Exam the draws fell on **AS-1.3.1** (Q1) and **AS-1.1.3** (Q2). Advanced Level points: K2 = 1, K3 = 2, K4 = 3.*

Exam allocation you must know

Chapter 1 = **4 questions / 8 points** of 45 questions and 80 points. In the official Sample Exam these are questions **#1 to #4** (1 + 3 + 1 + 3 points). The CT-SEC exam is **45 questions worth 80 points in 120 minutes** (**150 minutes** with the 25% non-native-language allowance) and the pass mark is **65% = 52 points**.

The one thing that decides this chapter

Testing proves; auditing and policy review only describe. The guaranteed K4 question (AS-1.2.2) asks how to determine whether policies and procedures are **effective**, and the syllabus answer is always the same: **use the results of security tests designed to verify or validate them** — because a policy can be in place and followed and still not protect the asset. The official answer to Q4 is literally "analyze the results from a security test to validate effectiveness". Any option built on static review alone, or on emerging threats alone, is the distractor.

Chapter framing — what makes security testing different

The chapter opens with one sentence worth memorising: **functional testing is based on risks, requirements, use cases and models; security testing is based on the security aspects of those specifications but also seeks to verify and validate security risks, security procedures and policies, attacker behavior and known security vulnerabilities.** That list — **risks · procedures and policies · attacker behavior · known vulnerabilities** — is the test basis the rest of the syllabus keeps returning to.

AS-1.1.1 (K2) — The Role of Risk Assessment in Security Testing

Original syllabus statement

Understand the role of risk assessment in supplying information for security test planning and design and aligning security testing with business needs.

Security test objectives are based on security risks, and those risks are identified by performing a **security risk assessment**. General risk management is assumed from Foundation Level and the Advanced Test Manager syllabus.

Risk is a measure of the extent to which an entity is threatened by a potential circumstance or event, and is typically a function of **(1) the adverse impacts that would arise if the circumstance or event occurs** and **(2) the likelihood of occurrence**.

Information security risks arise from the **loss of confidentiality, integrity, or availability** of information or information systems, and reflect potential adverse impacts to **organizational operations (mission, functions, image, reputation), organizational assets, individuals, other organizations, and a country** [NIST 800-30].

What a security risk assessment gives the tester

Role of the assessment	Syllabus wording to recognise
For the organization	Understand **which areas and assets may be at risk** and **determine the magnitude of each risk**.
For planning and design	**A rich source of information from which security tests can be planned and designed.**
For prioritization	**Prioritize security tests** so that the **highest level of test rigor and coverage** is focused on areas with the **greatest risk exposure**.
For business alignment	Prioritizing by the assessment makes tests **aligned with business security objectives** — **but only if** the assessment **accurately reflects the organization's security threats, the impacted stakeholders and the assets to be protected**.

The two weaknesses of any risk assessment

- **It is a snapshot.** Any risk assessment (security or otherwise) is **only a snapshot at a given point in time**, based on **limited information** that may lead to **invalid assumptions and conclusions**. **New threats emerge daily**, so assessments should be **performed at regular intervals** — some organizations every **three to six months**, others **annually**; the interval depends on the organization and **the degree of change it experiences**.
- **It depends on its participants' knowledge.** Risks are missed through **lack of detailed information**, or because people **do not understand security threats and risks**. Hence: **solicit input from a variety of people** and **pay careful attention to the level of detail** in what they provide.

The two remedies the syllabus names

Wrong assumptions are a **realistic expectation**. To deal with missing or incomplete risk information: **(1) use an established security risk assessment methodology as a checklist** (e.g. NIST 800-30), and **(2) get input from multiple people**. If a stem asks how to reduce the chance of missing risks, the answer is one of these two — not "run more tests".

AS-1.1.2 (K4) — Asset Identification

Original syllabus statement

Identify the significant assets to be protected, the value of each asset and the data required to assess the level of security needed for each asset.

Not all information to be secured is digital. Copied documents — contracts, plans, written notes, **logins and passwords in written form** — may have **high value**. The first question is therefore **which information is digital and which is not**, recognising that **the same asset may exist in both forms**.

The syllabus structures asset identification as **five questions**. A K4 item will hand you a scenario and expect you to work through them; learn them as a sequence.

#	Question	What the syllabus lists
1	**Which assets are valuable?**	High-value **information**: customer data · business plans · proprietary software · system documentation · company pictures and diagrams · **intellectual property** (processes, trade secrets) · financial spreadsheets · presentations and training courses · documents · emails · employee records · tax statements. **Physical or intangible** assets: **physical prototypes** of devices under development · **the ability to deliver services** · **company reputation and trust**.
2	**How valuable is the asset?**	Some have a tangible value; others are **measured in the costs and consequences of their loss**. Methods: **future revenue** the asset generates · **value to a competitor** · **time and effort to recreate** it · **fines and penalties for not producing it** when needed (audit, lawsuit) · **fines and penalties for losing customer data**.
3	**Where are the digital assets located?**	Historically servers, desktops, CDs, disks — **an outdated and disorganized approach**, but sensitive data may still sit on **old CDs, DVDs, USB drives**. More secure: **secure enterprise servers with strong encryption**, requiring **authentication and authorization**, plus e.g. **digital certificates** for Internet access. Now also **mobile devices, thumb drives and cloud storage** (a **new set of concerns based on data access**).
4	**How are the digital assets accessed?**	**LAN or Wi-Fi** · **remote access via VPN or cloud drive** · **passing physical data stores (CDs, DVDs, USB) person to person — low-tech but very common** · **sending files by email**.
5	**How are the digital assets secured?**	**Encryption** (what type and strength, **who has the keys?**) · **authentication and tokens** (digital certificates? password policies **adequate and followed**?) · **authorization** (which **levels of privilege** have been granted?).

The insider example the syllabus chose

Storage matters because **people entrusted with sensitive data have simply walked out of a building with a hard drive** of private customer and business data. The syllabus cites a **hard drive stolen from a secured area at a government security agency** containing payroll and bank information for **over 100,000** current and former workers [Washington Post, 2007]. Location and physical control of data are asset questions, not only technical ones.

How to answer a K4 asset item. Read the scenario and classify each item it mentions: is it an **asset** (information, physical or intangible)? a **value method** (revenue, competitor value, recreation cost, fines)? a **location**? an **access route**? a **protection** (encryption, authentication, authorization)? The option that names the **data required to assess the level of security** usually combines **value + location + access + protection** — not value alone.

AS-1.1.3 (K4) — Analysis of Risk Assessment Techniques

Original syllabus statement

Analyze the effective use of risk assessment techniques in a given situation to identify current and future security threats.

A security risk assessment is **very similar to a standard risk assessment**, the main difference being **the focus on security-related areas**. It **should include the perspectives of external security testing stakeholders** — people or parties **outside the company** with a clear stake in the security of the project or product.

External stakeholders and why each is included

External stakeholder	Why the syllabus includes them
Customers and users	Useful for **understanding perspective, getting input for security testing, and establishing good communication**.
The public and society	Important to convey that **information security is a community effort and responsibility**.
Regulatory agencies	Necessary for **ensuring compliance with applicable laws** regarding information security.

How the official exam used this table

Sample Q2: you must keep **external vendors compliant with government-mandated guidelines**. The answer is **federal and local agencies that communicate the guidelines** — they are the **source** of the guidelines, and the guidelines may change, so the channel to them must stay open. Customers, users, vendors and the public all need to be informed, but **the information comes from the regulators**. Map the stem's concern (compliance with law) to the stakeholder whose row says "compliance" — **regulatory agencies**.

The NIST 800-30 task lists — three phases

Phase	Tasks [NIST 800-30]
Preparing for a risk assessment	Identify the **purpose** · identify the **scope** · identify the **assumptions and constraints** · identify the **sources of information** to be used as inputs · identify the **risk model and analytic approaches** (assessment and analysis approaches).
Conducting a risk assessment	Identify **threat sources** relevant to the organization · identify **threat events** those sources could produce · identify **vulnerabilities** that could be exploited, and the **predisposing conditions** affecting successful exploitation · determine the **likelihood** that sources would **initiate** events and that the events **would be successful** · determine the **adverse impacts** to operations and assets, individuals, other organizations and the nation.
Communicating and sharing	**Communicate** the risk assessment results · **share information** developed during the assessment to **support other risk management activities**.

Order inside "conducting" is examinable logic: sources → events → vulnerabilities and predisposing conditions → likelihood → impact. A threat source produces a threat event that exploits a vulnerability; only then can you say how likely and how damaging it is. An option that determines impact before identifying threat sources has the chain backwards.

"Current and future" threats. The LO says to identify **current and future** security threats. That is why the assessment must be **repeated at intervals** (§1.1.1), why **emergent vulnerabilities** arise as missions, environments and technologies change (§1.3.2), and why **continuous monitoring** is recommended. A technique that only catalogues today's known attacks is incomplete.

AS-1.2.1 (K2) — Understanding Security Policies and Procedures

Original syllabus statement

Understand the concept of security policies and procedures and how they are applied in information systems.

Policies **vary among organizations** by business model, industry and unique risks, but **their goals are similar**. **The basis of all security policies should be a security risk assessment** that examines specific threats and how they impact the organization [Jackson, 2010]. The syllabus then lists **eighteen example policies**. One K2 question is guaranteed on this objective, and it is usually decided by **matching a behaviour to the policy that governs it**.

The eighteen example security policies

Policy	What it defines — the words that identify it
Acceptable Use	Practices a user **must adhere to**; **acceptable and non-acceptable behavior** using networks, websites and data; applies to **internal and external users**; should define rules for **acceptable, unacceptable and required behavior**.
Minimum Access	The **minimum levels of access needed to perform certain tasks** — prevents access rights **in excess of what is needed**, which create opportunities for **inadvertent or intentional abuse of privileges**.
Network Access	Criteria for accessing **LANs and wireless networks**; what is permissible on the network; **often prohibits users from adding unauthorized devices such as routers and hot spots**.
Remote Access	What is needed so **remote network access** can be granted to internal and external users; **VPN usage** is often covered here.

Policy	What it defines — the words that identify it
Internet Access	Permissible **Internet usage by employees and guests** — which **types of websites** may be accessed, and whether **non-business use** is allowed. Sometimes split out from acceptable use because so many people do business on the Internet.
User Account Management	**Creation, maintenance and deletion** of user accounts, plus **regular auditing of accounts**.
Data Classification	Which data are **sensitive** and must be secured, so controls match **value to the organization and its customers. The business area that creates the data classifies it.** Example scale: **public · confidential · highly confidential · private · secret**.
Configuration and Change Management	How security settings are applied to devices and applications; **standard configurations**, an **approval process for all changes**, and a **rollback process**. Risk: an **unauthorized change** creates an **undetected vulnerability**.
Server Security	Responsibility of **server owners** to follow corporate and industry practice; **baseline configurations** defined and maintained; backup and recovery; **limiting active services** to those necessary; monitoring and auditing.
Mobile Devices	Lost or stolen laptops and phones, **high malware risk**; which data must be **encrypted**, anti-malware currency, **passwords**, which organizational information may reside on the device, **cable locks**, reporting **lost or stolen devices**.
Guest Access	Protects the organization while **hosting guests on its networks** — guests **read and agree to the acceptable use policy**, e.g. sign it and receive **a code for temporary access**.
Physical Security	Controls for **physical facilities**, because **physical proximity** raises breach risk; also **power loss, theft, fire, natural disasters**, and which devices may be **taken out of or brought into** sensitive areas.
Password Policy	Minimum requirements for **strong passwords**; time between **mandatory changes**; protecting privacy — **no "remember password" in browsers, no sharing, no sending passwords by email**.
Malware Protection	Framework of defenses and behaviors for **preventing, detecting and removing malware** — e.g. **restricting USB drives**.
Incident Response	How to respond to a **security-related incident** — **in place before** an incident, to avoid case-by-case decisions; covers **communication, media responses and law enforcement notification**.
Audit Policy	**Authorizes auditors to request access** to systems — log data, network traffic records, forensic data.
Software Licensing	How software is obtained and licensed; licence violations bring **fines and legal action**; key prohibition: **downloading and installing unapproved software**.
Electronic Monitoring and Privacy	The organization's **right and responsibility to monitor** communications (email, social media); which monitoring is done and which data is collected; **legal counsel is needed** because laws vary by country.

Data classification — the five levels in order

Level	Who may see it	Example
Public	**Anyone, inside or outside** the organization.	Outward-facing documents and webpages.
Confidential	**Normally the default** for internally created documents; **only authorized users**; **NDAs** often required before sharing with third parties.	A **sales report**; internal email, reports, presentations.
Highly confidential	**Only certain people**; sharing **not allowed except with explicit permission of the data owner**.	**Trade secrets, strategic plans, product designs, nonpublic financial data**.
Private	Often restricted to **officers of the organization**, specifically authorized; disclosure could cause **major negative impact such as financial harm**; **protect with extreme care**.	**R&D information, merger and acquisition plans, customer credit card and account information**.
Secret	Corporate: information **obtained from an external party** that must not become known **inside or outside**; comparable to highly confidential but **may have no tangible value for the organization itself** — so **not a trade secret**. Military/government: known only to people with **security clearance**.	A **consultant's design document** for a multi-company technology; particulars of **defense research projects**.

Policies versus procedures

Security procedures specify the steps to be taken in **implementing a specific policy or control**, and the steps to be taken **in response to a specific security incident**. **Policies, standards and guidelines describe the controls that should be in place; a procedure explains how to implement them step by step** — e.g. a procedure for **granting user access levels** so that the rights satisfy the applicable policy. Formal, documented procedures **facilitate implementation** of policies and mandated controls.

How the official exam used this objective

Sample Q3 asked for **a consequence of a policy that minimizes access to a system or device to acceptable levels**. The official answer: **devices that do not conform are removed from the wireless network** — non-conforming devices are removed **until they conform**. Rejected: "more devices are added" (not an expected result), "controls of self-provisioning devices such as routers are prohibited" (such controls are **encouraged**), and "VPN access is severely restricted" (access is **controlled, not severely limited**). The wording blends **minimum access** with the **network access** policy's ban on unauthorized routers and hot spots — learn both rows together.

AS-1.2.2 (K4) — Analysis of Security Policies and Procedures

Original syllabus statement

Analyze a given set of security policies and procedures along with security test results to determine effectiveness.

Before evaluating a set of policies and procedures, **determine the objective(s) of the evaluation** and **define criteria by which to judge adequacy**. Criteria may come from standards such as **COBIT, ISO 27001 or PCI**. It is also necessary to define:

- **Which resources are needed** in terms of skills and knowledge in the areas being evaluated
- **How to measure the adequacy** of the policies and procedures
- **What to measure and assess** — e.g. **effectiveness, efficiency, usability, adoption**
- **Where the policies and procedures are located** in the organization
- **A checklist** to guide the assessment and add consistency — it **directs the auditor where to look and what to expect**

What the auditor does — static and dynamic tasks

Tools such as **password audit tools** help test whether controls accomplish their goals and generate data for later risk assessment. The auditor looks for **"proof" of compliance** to policies, controls and standards. Some tasks are **static**, others — such as **observing processes in action** — are **dynamic**:

Auditor task	Static or dynamic? (guide's reading)
Reviews **system documentation**	Static
Surveys people on their perception of effectiveness	Static (opinion)
Interviews key personnel involved in the controlled processes	Static (opinion)
Witnesses systems and processes being performed	**Dynamic**
Analyzes **previous audit results** to discover trends	Static
Analyzes **logs and reports**	Static (evidence)
Reviews **technical control configuration** — firewall, IDS configuration	Static
Samples data transactions for anomalies or suspicious transactions	Dynamic / evidence-based

*The syllabus names only **witnessing processes in action** as a dynamic task. The other labels in this table are this guide's reading and are not examined as such.*

Controls — three types, four functions

Security controls are technical or administrative safeguards or countermeasures to avoid, counteract or minimize loss or unavailability due to threats acting on their matching vulnerability, i.e. security risk [Northcutt, 2014]. Example: in a payroll system, **two people must separately approve a change to an employee's pay rate**. Security testers must know their organization's controls and **include tests for them**.

Control types (categories)	Specific controls under each category
Administrative · Technical · Physical	**Preventive · Detective · Corrective · Recovery**

The types **work together**: **in general, controls must be provided from each category** to effectively protect an asset [Jackson, 2010]. The **SANS Top 20 Critical Security Controls** list is cited as a reference.

Why security tests are needed on top of policy analysis

The primary difference between security testing and a **static analysis** of policies and procedures is **the use of results from tests designed specifically to verify or validate their effectiveness**. These tests **focus on the risk that a security policy may be in place, may be followed, but is not effective in protecting assets.**

- You may be **told** during an assessment that certain tasks are performed; **a security test of those tasks** shows how effective they are **in practice**.
- A **password policy** may seem reasonable and effective **on paper**, but **when a password cracking tool is used, the procedure may fall short of its goals**.
- Policies and procedures are **a source of security tests**, but **attacks are always evolving** — new attacks emerge and new defects become evident — so testers must also test **from the attacker mindset**.

The K4 decision rule

Asked for the **optimum way to determine effectiveness** of policies and procedures (Sample Q4, 3 points): **analyze the results from a security test to validate effectiveness.** Reject: **static analysis alone** (static analysis belongs on the code, if anywhere), **current threats and attacks only** (the focus must also include configurations and more), **emerging threats only**. The syllabus's concern is a policy that is **in place and followed but ineffective** — only a test can expose that.

AS-1.3.1 (K2) — Security Auditing and the Purpose of a Security Audit

Original syllabus statement

Understand the purpose of a security audit.

Security auditing is a manual examination and evaluation that identifies weaknesses in an organization's security processes and infrastructure. Audits at the **procedural level** (e.g. reviewing internal controls) may be **manual**; audits at the **architectural level** are often performed with **security audit tools**, possibly aligned with a vendor's networking, server and workstation solution.

Like testing, **an audit does not guarantee that all vulnerabilities will be found** — it is **one more activity** to identify problem areas and **indicate where remediation is needed**.

Auditing versus testing — the scope distinction

	Security auditing	Security testing
Scope	**Much larger** than testing	Narrower, technology-focused
Typical targets	**Procedures, policies and controls that are difficult to test in a direct way**	**Technologies that support security — firewall configuration, correct application of authentication and encryption, application of user rights**
Relationship	**Identifies deficiencies and areas of importance to test**	**Proves or disproves that the security controls are actually in place and working effectively**

	Security auditing	Security testing
Overlap	Some auditing approaches **include testing** as part of the audit	Testing from an attacker perspective = **ethical hacking / penetration testing**

The five pillars of security auditing [Jackson, 2010]

Pillar	Key syllabus points
Assessment	Document and identify **potential threats, key assets, policies and procedures, and management's tolerance for risk**. **Not one-time events** — performed regularly, which also shows whether policies are **still relevant and effective**.
Prevention	**Beyond technology**: administrative, operational and technical controls; policies, procedures and **awareness**. Preventing all attacks is **unrealistic**, but combined defenses make attacks **much more difficult**.
Detection	How a breach or intrusion is **identified**. Without it you **do not know whether the network has been compromised**. **Early detection enables appropriate reaction** to recover services quickly.
Reaction	Reaction time is greatly reduced with good defenses and detection. **The speed and efficiency of incident response is a key indicator** of the effectiveness of an organization's security efforts.
Recovery	Determine **what occurred** so recovery does **not recreate the same vulnerability**. **Does not end with restoring the system** — **root cause analysis** decides what process, procedure and technology changes reduce recurrence. The auditor ensures there is **a recovery plan that includes preventing similar incidents**.

What a security audit might detect (§1.3.1)

Finding	Syllabus example
Inadequate physical security	Policy requires encryption of customer data, but a **weekly printed customer report** is thrown in the trash by managers — **"dumpster diving"**.
Inadequate password maintenance	Users change passwords every 30 days but **alternate between "PasswordA" and "PasswordB"**. (**Password history** is a common feature of password auditing tools.)
Inadequate controls for user rights and sharing privileges	Users with **more access rights than their job needs**; an individual's files **shared on the network** when they should be private — especially notebook users on home or public **Wi-Fi**.
Inadequate server-level security	**Port allocation and security · protection of data · protection of user accounts** (logins and other sensitive information).
Inadequate application of vendor security updates	Patches not applied — **the official answer to Sample Q1**.
Inadequate intrusion detection mechanisms	Breaches go unnoticed.
Inadequate response plans in the event of a breach	No incident response readiness.

Purpose versus practice — the Q1 trap

Sample Q1 asked for **a purpose of a security audit**. Correct: **to reveal insufficient patch updates provided by the vendor**. The distractors — prevent simple passwords, halt unauthorized intruders, force periodic password changes — are **good practices or controls**, not the purpose of an audit. **An audit reveals and evaluates; it does not prevent, halt or enforce.** Any option whose verb is a control verb (prevent, halt, require, block) is not describing an audit.

§1.3.2 — Risk Identification, Assessment and Mitigation (supports AS-1.1.x and 1.3.1)

Once the audit identifies problem areas, **risk must be evaluated and an improvement plan put in place**. **Risk identification** is **documenting a risk or an area of risk**; **risk assessment assigns a value** to the identified risks. **Traditional IT risk assessment models are not sufficient for IT security risks** — the model must be **specifically oriented to IT security risk profiles**.

Risk exposure — the one formula in the chapter

Risk exposure = potential impact (or loss) × likelihood of that loss occurring. Likelihood may be determined with **NIST SP 800-30** (Guide for Conducting Risk Assessments) or the **OWASP Risk Rating Methodology**. The syllabus's illustration: one customer's account is compromised — what if that customer had **$100 million** on deposit?

The five risk factors (NIST 800-30)

Factor	Definition and the points that get examined
Threat	**Any circumstance or event with the potential to adversely impact** operations and assets, individuals, other organizations or a country **through an information system** via **unauthorized access, destruction, disclosure, modification of information, and/or denial of service**. Threat events are caused by **threat sources**, characterised by **intent and method** targeted at exploiting a vulnerability, or a **situation and method that may accidentally** exploit one. **Source types: hostile cyber or physical attacks · human errors of omission or commission · structural failures of organization-controlled resources · natural and man-made disasters, accidents and failures beyond the organization's control. Multiple sources can cause the same event** — a provisioning server taken offline by DoS, a malicious admin, an admin error, a hardware fault or a power failure.
Vulnerability	**A weakness in an information system, system security procedures, internal controls, or implementation that could be exploited by a threat source.** Mostly linked to controls **not applied** or **applied with a weakness**. **Emergent vulnerabilities** arise over time as missions, environments and technologies change — **controls degrade**, so risk assessments must be **maintained across the lifecycle** with **continuous monitoring**. Vulnerabilities also live in **governance structures**, **external relationships** (energy, supply chains, telecoms), **mission/business processes** and **enterprise/security architectures** (e.g. lack of diversity or resiliency).
Predisposing condition	Conditions that affect the likelihood that a threat event, once initiated, results in adverse impact (grouped with vulnerabilities by the syllabus).
Impact	**Magnitude of harm** from **unauthorized disclosure, modification, destruction of information, or loss of availability**. Felt by heads of agencies, mission/business owners, information owners, process owners, system owners, and the public relying on the organization. Organizations should document **the process, assumptions, sources and methods, and rationale** for impact determinations.
Likelihood	The **probability (or possibility) that the threat event will result in an adverse impact, regardless of the magnitude of harm**. Combines likelihood of **initiation** with likelihood of **impact**. For **adversarial threats**: **adversary intent, capability and targeting**. For **non-adversarial** events: **historical evidence, empirical data**. Always assessed **within a specific time frame**.

Scoring and the risk matrix

Likelihood and impact may be scored **0–9** against specific criteria, or estimated **low / medium / high**. The syllabus's data-privacy example:

Band	Likelihood criterion (data privacy)	Impact criterion
0 – <3 Low	Private data **not stored on local devices** and **encrypted** on secure media	Fewer than **200** people affected
3 – <6 Medium	Private data **may reside on notebooks, but encrypted**	**200 to 1,000** people
6 – 9 High	**Not known** whether private data resides on local devices; **encryption cannot be assured**	Over **1,000** people

Overall risk severity matrix (syllabus example)

Impact ↓ / Likelihood →	Low	Medium	High
High	Medium	**High**	**Critical**
Medium	Medium	Medium	High
Low	Low	Low	Medium

- **Medium likelihood × high impact = high** — the syllabus's worked reading of the matrix.
- **Business impact information beats technical impact information**; use technical impact only when there is no business information.
- The report should state **whether a risk is ongoing** — **continual risks indicate increased likelihood** of loss.
- **The higher the severity, the more immediate the required response.** The **level of detail** matches the **purpose** of the assessment.

§1.3.3 — People, Process and Technology

Every security incident — **from break-ins to lost customer records** — can usually be traced back to **a deficiency attributable to people, process, or technology** [Jackson, 2010]. Together the three form an **"iron triangle"**; **ignore any one and the whole IT delivery and security effort suffers**.

Component	Syllabus points
People	End-users, sysadmins, data owners, managers — varying **skills, attitudes and agendas**. **Policies and controls are ineffective if people do not follow them**; remediation may be **awareness training or penalties for noncompliance**.
Process	How IT and security services are delivered; procedures and standards. To be effective processes must be **defined, up to date, consistent, and follow best practices**; they define **roles, responsibilities, controls, tools and steps**.
Technology	Facilities, equipment, hardware and software. Lets people do repetitive jobs **faster and with fewer errors**; some tasks (e.g. **password enforcement**) are impossible without tools. Risk: **technology used incorrectly helps people make mistakes faster**.

The auditor should look at a system from the perspective of an attacker and anticipate how people, process or technology could be exploited. Management is **often surprised** that mechanisms they thought secure are not. **The only way to know for sure is to test from an attacker perspective — ethical hacking or penetration testing.** This is where auditing and testing meet most directly: **auditing identifies deficiencies; testing proves or disproves that controls are in place and effective.**

> **The tax-agency scenario — accepting a known risk has a price**
>
> An audit finds criminals can file **fraudulent tax returns** and collect refunds; **security testing confirms it** and the risk is rated **critical**. The agency acknowledges the risk but **decides not to act until next year**. Defrauded taxpayers who **followed all prescribed procedures** can claim against an agency **that was aware of the defect — the agency is liable**. Lesson: once testing confirms a risk, deferring mitigation shifts liability onto the organization.

Section 2 — Key Concepts

Section 1 gives the syllabus wording objective by objective. This section explains what that wording means. Each card builds one idea in order: plain words first, then how it works, an example, how the exam uses it, and what it is easily confused with. Read the cards in order, because each one assumes the ones before it.

2.1 The storyline of Chapter 1

Chapter 1 is one argument told in four steps. **(1)** You cannot test everything, so you start from **risk**: what could go wrong, how likely is it, and how bad would it be. **(2)** To judge risk you must know your **assets**: what is valuable, where it is, how people reach it and how it is protected. **(3)** The organization answers those risks with **policies** (what must happen), **procedures** (the steps to make it happen) and **controls** (the safeguards that enforce it). **(4)** Finally you check whether those answers actually work. An **audit** examines and finds weaknesses. A **security test** proves or disproves that a control works in practice.

If you keep this chain in mind (**risk → assets → policies and controls → audit and test**), every Chapter 1 question becomes a question about one link in it.

2.2 Risk and how it is measured

Risk, security risk and risk exposure	
In plain words	A **risk** is something bad that **might** happen. How much it matters depends on two things: **how likely** it is to happen, and **how much damage** it would do if it did. A **security risk** is the special case where the damage is a loss of **confidentiality** (someone sees what they should not), **integrity** (someone changes what they should not) or **availability** (people cannot use the system or data when they need it).
How it works	**Risk exposure = impact × likelihood.** It is one number (or a level such as low, medium, high) that lets you **compare** risks and decide which to deal with first. Likelihood and impact are each scored against **written criteria**, for example 0–9 or low / medium / high, and then combined in a **risk matrix**. The syllabus reads its matrix as **medium likelihood × high impact = high** risk.
Example	A laptop that holds unencrypted customer records is lost. **Likelihood:** laptops are lost every month in a large company, so this is high. **Impact:** 5,000 customers are affected and regulatory fines follow, so this is also high. **Exposure:** critical. Compare a public marketing PDF on the same laptop: the likelihood of loss is the same, but the impact is close to zero, so the exposure is low.
Exam angle	If a stem says “impact multiplied by likelihood”, the term is **risk exposure**. If it asks which impact information to prefer, the answer is **business impact**. Use technical impact only when no business information exists. **The higher the severity, the more immediate the response.**
Don’t confuse	**Risk identification** (writing the risk down) is not **risk assessment** (giving it a value). The syllabus also uses “risk assessment” for the **whole** NIST process. Read the stem to see which meaning is intended.

The NIST risk vocabulary: threat source → threat event → vulnerability → likelihood → impact	
In plain words	These words describe **one chain of cause and effect**. A **threat source** (who or what) causes a **threat event** (what happens), which exploits a **vulnerability** (the weakness). **Predisposing conditions** make success easier or harder. **Likelihood** says how probable it is that this chain produces harm, and **impact** says how much harm.

The NIST risk vocabulary: threat source → threat event → vulnerability → likelihood → impact	
How it works	**Threat source**: one of four kinds. **Hostile attacks** (cyber or physical), **human error** (of omission or commission), **structural failure** of the organization's own resources (hardware, software, environment), or **natural and man-made disasters** outside the organization's control. **Vulnerability**: a weakness in a system, a security procedure, an internal control or an implementation. It is usually a control that is **missing** or **applied badly**. **Emergent vulnerabilities** appear later as the mission, the environment or the technology changes and controls degrade. That is why risk is **monitored continuously**. **Likelihood**: for **adversarial** threats, judge the attacker's **intent, capability and targeting**. For **non-adversarial** threats (errors, failures, disasters), use **historical evidence and empirical data**. Always assess it **within a stated time frame**. **Many sources can cause the same event.** A provisioning server can go offline because of a DoS attack, a malicious administrator, an administrator's mistake, a hardware fault or a power cut.
Example	**Source:** a criminal group (adversarial, with high intent and capability). **Event:** a phishing email that harvests passwords. **Vulnerability:** staff not trained to spot phishing, and no second factor on webmail. **Predisposing condition:** the company's email-address format is public. **Likelihood:** high within the next 12 months. **Impact:** mailbox takeover and invoice fraud.
Exam angle	The NIST **conducting** order is examinable logic: **sources → events → vulnerabilities and predisposing conditions → likelihood → impact.** An option that determines impact **before** identifying threat sources has the chain backwards.
Don't confuse	A **threat** is the potential event. A **vulnerability** is the weakness the event exploits. A **risk** combines the two with likelihood and impact. "Unpatched server" is a vulnerability, not a threat. "Ransomware gang" is a threat source, not a risk.

2.3 Why the risk assessment drives security testing

The risk assessment is the starting point of security testing	
In plain words	**Security test objectives are based on security risks**, and the risks come from a **security risk assessment**. The assessment tells the tester **what to test, how hard to test it, and in what order**.
How it works	It is a **rich source of information** for **planning and designing** tests. It lets you **prioritize**: the **highest rigor and coverage** go where **risk exposure is greatest**. It **aligns testing with business security objectives**, but **only if** it accurately reflects the organization's real **threats, impacted stakeholders and assets**. A wrong assessment produces well-organized testing of the wrong things.
Why it matters	**It is a snapshot.** It is true only at the moment it was made, and it is based on limited information. New threats appear daily, so it must be **repeated at regular intervals**. Some organizations repeat it every **3–6 months**, others **annually**. The more the organization changes, the more often it should be repeated. **It depends on its participants.** Risks are missed when information is incomplete or when the people involved do not understand security threats.
Example	An online shop's assessment ranks card-payment fraud as critical and the product-review page as low. The test plan therefore spends most of its effort on the payment flow (injection, session handling, authorization) and only a light scan on reviews. Six months later the shop adds a mobile app. The old assessment no longer reflects the attack surface, so it is **repeated** before the next test cycle.
Exam angle	If a stem asks how to reduce the chance of **missing risks**, the answer is one of the syllabus's two remedies: **(1) use an established methodology (e.g. NIST 800-30) as a checklist**, and **(2) get input from many different people**. "Run more tests" is not one of them.
Don't confuse	The assessment **guides** testing. It does not **replace** testing. And it is never "done once". Treat any option that calls it permanent or complete as a distractor.

Identifying assets: the five questions (AS-1.1.2, a K4 pool)	
In plain words	Before you can say how much security an asset needs, you must answer **five questions** about it: **which** assets are valuable, **how valuable** each one is, **where** the digital ones are, **how** people reach them, and **how** they are protected.
How it works	**Which?** Assets are **information** (customer data, business plans, source code, intellectual property, employee and tax records, emails), but also **physical** items (prototypes) and **intangibles** (**the ability to deliver services, reputation and trust**). **Not everything valuable is digital.** A printed contract or a written-down password counts too. **How valuable?** The syllabus gives five measures: **future revenue** from the asset, **value to a competitor**, **cost and effort to recreate it**, **fines for not being able to produce it** (in an audit or lawsuit), and **fines for losing customer data**. **Where?** Servers, desktops, **old CDs, DVDs and USB sticks**, mobile devices and **cloud storage**. Each location raises different access concerns. **How accessed?** LAN or Wi-Fi, **VPN or cloud drive**, **physical media handed from person to person** (low-tech but very common), and **email attachments**. **How secured? Encryption** (what type and strength, and **who holds the keys**), **authentication** (certificates, tokens, password policy, and whether that policy is **followed**), and **authorization** (what privilege levels have been granted).
Example	A hospital's patient records. **Which:** the records, plus the hospital's ability to treat patients (an intangible). **How valuable:** regulatory fines per lost record, plus lost trust. **Where:** the clinical database, nightly backups and doctors' tablets. **Accessed:** ward Wi-Fi, VPN for on-call doctors, exported USB sticks for research. **Secured:** the database is encrypted, the USB sticks are not, and the research team shares one login. The security level needed, and therefore the test focus, follows from the weak answers: **USB sticks and shared logins**.
Exam angle	In a K4 asset question, the option that names **value + location + access + protection** beats any option that looks at **value alone**. The syllabus's insider story (a hard drive with payroll data on 100,000+ people walked out of a secure area) shows that **location and physical control are asset questions too**.
Don't confuse	**Value** is only question 2 of 5. A cheap asset in an exposed location can need more protection than a valuable one that is well secured.

External stakeholders in the risk assessment (AS-1.1.3)	
In plain words	A security risk assessment should include people **outside** the company who have a real stake in the security of the product. The syllabus names three groups, and each has a **different reason** for being included.
How it works	**Customers and users**: to understand their **perspective**, get **input for testing** and keep **good communication**. **The public and society**: to show that information security is a **community effort and responsibility**. **Regulatory agencies**: to **ensure compliance with applicable laws**.
Example	A payroll provider must keep its subcontractors compliant with new government data-protection guidelines. Customers care, and the public cares, but the **guidelines themselves come from the regulator**, and they may change. So the regulator is the stakeholder to keep the channel open with.
Exam angle	**Match the concern in the stem to the stakeholder's reason.** "Compliance", "law", "government-mandated" → **regulatory agencies** (official Sample Q2, 3 points). "Perspective", "input", "communication" → customers and users.
Don't confuse	Do not confuse these **external risk-assessment stakeholders** (Chapter 1) with the **six stakeholder groups and their benefits** in Chapter 2 (executives, senior management, customers, compliance, regulatory and privacy officers). They are different lists for different questions.

The NIST 800-30 process: prepare → conduct → communicate	
In plain words	NIST SP 800-30 is the methodology the syllabus uses as its example. It runs in **three phases**: get ready, do the assessment, then share the results.
How it works	**Prepare**: decide the **purpose**, the **scope**, the **assumptions and constraints**, the **sources of information**, and the **risk model and analytic approach**. **Conduct**: identify **threat sources → threat events → vulnerabilities and predisposing conditions**, then determine **likelihood**, then determine **impact**. **Communicate and share**: **communicate the results** and **share the information** so it supports other risk-management activities, including security testing.
Example	Preparing for a cloud migration: the purpose is to decide which data may move, the scope is three applications, the assumption is that the provider's physical security is adequate, the sources are vendor reports and past incidents, and the model is a 0–9 scoring scheme. Only after this do you start listing threat sources.
Exam angle	Expect "which task belongs to which phase?" or "what is the correct order?". Choosing the **risk model** is **preparation**, not conducting. **Sharing** results to support other activities is the **third** phase.
Don't confuse	NIST's three phases are **not** the five audit pillars (assessment, prevention, detection, reaction, recovery). Both lists appear in Chapter 1.

2.4 Policies, procedures and controls

Policy vs procedure vs control	
In plain words	A **policy** says **what** must be true ("passwords must be strong and changed regularly"). A **procedure** says **how**, step by step ("to reset a password: verify identity, issue a temporary password, force a change at first login"). A **control** is the **safeguard** that makes it happen or detects when it does not (the login system that rejects short passwords).
How it works	**The basis of every security policy should be a security risk assessment.** Policies exist to answer risks. Policies, standards and guidelines **describe the controls that should be in place**. **Procedures explain how to implement them**, and also how to **respond to a specific incident**. A **control** is a technical or administrative **safeguard or countermeasure** that **avoids, counteracts or minimizes loss** from a threat acting on a vulnerability. The syllabus's example: **two people must separately approve a pay-rate change**.
Example	Policy: "Remote access is allowed only through the corporate VPN." Procedure: "To request VPN access: the manager approves the ticket, IT issues a certificate, and the user installs the client." Controls: the firewall blocks non-VPN remote connections (technical, preventive), and a monthly report lists VPN accounts with no recent use (administrative, detective).
Exam angle	One AS-1.2.1 question is **guaranteed**. It is usually "which policy governs this behaviour?" Learn the **identifying phrase** of each of the 18 policies (Section 3, table 3.2), not the whole text. Example: "adding routers or hot spots" → **Network Access**. "Rights in excess of what is needed" → **Minimum Access**.
Don't confuse	**Minimum Access** means access is **controlled to what the task needs**, not **severely restricted**. In official Q3, "VPN access is severely restricted" is the wrong option. And controls over self-provisioned devices are **encouraged**, not prohibited.

Control types (administrative, technical, physical) × control functions (preventive, detective, corrective, recovery)	
In plain words	Every control can be described in two ways at once: **what kind of thing it is** (a rule, a technology or a physical barrier) and **what job it does** (stops an attack, notices one, repairs the damage, or restores service).

Control types (administrative, technical, physical) × control functions (preventive, detective, corrective, recovery)	
How it works	**Administrative**: rules, policies, approvals, training. **Technical**: software and hardware mechanisms. **Physical**: locks, badges, guards, fences. **Preventive**: stops the event from happening. **Detective**: notices that it happened or is happening. **Corrective**: fixes the cause or limits the damage afterwards. **Recovery**: brings the system back to normal operation. **Rule from the syllabus:** in general, controls are needed **from each category** to protect an asset effectively. One kind alone is not enough.
Example	Protecting a server room: the badge reader is **physical + preventive**, CCTV is **physical + detective**, the visitor-log review is **administrative + detective**, and the off-site backup restore is **technical + recovery**.
Exam angle	If an option claims a single control type is sufficient, it contradicts the syllabus. In Section 3, table 3.4 is a self-test grid. Fill in one control per cell.
Don't confuse	The syllabus calls the first list **types** and the second list **specific controls**. Other books call them "categories" and "functions". The terms differ, but the idea is the same. Do not mix the two lists in one answer (for example, "a detective type").

Data classification: the five levels	
In plain words	Data classification puts every piece of data on a **sensitivity ladder** so that the protection matches the value. **The business area that creates the data classifies it.**
How it works	**Public**: anyone may see it (web pages, press releases). **Confidential**: the **default** for internal documents. Only authorized users may see it, and an NDA is often needed before sharing with third parties (a sales report). **Highly confidential**: only certain named people. Sharing requires the **data owner's explicit permission** (trade secrets, strategic plans, product designs). **Private**: usually restricted to **officers** of the organization. Disclosure could cause **major harm, such as financial harm** (M&A plans, R&D, **customers' card and account data**). **Secret**: in a company, information **received from an external party** that must not become known **inside or outside**. It may have **no tangible value to the organization itself** (a consultant's design document for a multi-company project). In government, it is information for people with a **security clearance**.
Example	A bank receives a partner's unreleased chip design under contract. It is worthless to the bank commercially, but disclosure would be a disaster. That is **secret**, not highly confidential, and it is **not a trade secret** (because it is not the bank's).
Exam angle	Typical K2 traps: which level is the **default** (confidential), **who classifies** (the creating business area), and why "secret" differs from "highly confidential" (external origin, no tangible value to the holder).
Don't confuse	"Private" here is a **classification level**, not the general idea of "personal data". Customer card data sits at **private**, which is above highly confidential.

2.5 Checking that it works: evaluation, audit and test

"In place, followed — and still not effective" (AS-1.2.2, guaranteed K4)	
In plain words	A policy can exist on paper (**in place**), and people can obey it (**followed**), and it can **still fail** to protect the asset. Only a **test designed to verify or validate it** shows whether it actually works.

"In place, followed — and still not effective" (AS-1.2.2, guaranteed K4)	
How it works	**Before evaluating** policies: set the **objectives** of the evaluation and the **criteria** for adequacy (from **COBIT, ISO 27001, PCI** ...). Then decide the **resources and skills** needed, **how to measure adequacy**, **what to measure** (effectiveness, efficiency, usability, adoption), **where the policies are**, and prepare a **checklist**. The auditor gathers **evidence of compliance**: documents, surveys, interviews, logs, configurations, previous audits, **witnessing processes**, and **sampling transactions**. **The primary difference** between security testing and a static review of policies is **the use of results from tests designed to verify or validate effectiveness**.
Example	Policy: passwords of at least 8 characters, changed every 90 days. Audit: the configuration enforces it, and every user complies. **Test:** a password-cracking tool recovers 35% of the hashes in an hour ("Summer2026!", "Company123"). The policy is in place and followed, but **not effective**. The finding goes to management as evidence, and the policy is revised (longer passphrases, a banned-word list).
Exam angle	Official Q4 asks for the **optimum** way to show effectiveness: **analyze the results from a security test to validate effectiveness.** Reject static analysis alone, tests limited to "current threats" only, and tests limited to "emerging threats" only.
Don't confuse	**Compliance ≠ effectiveness.** An audit can show compliance. Only a test shows effectiveness. Also, policies are **a** source of tests, not the only one. Attacks evolve, so testers must also think like an attacker.

The security audit: what it is for	
In plain words	A **security audit** is a **manual examination and evaluation** that **finds weaknesses** in an organization's security processes and infrastructure. It **reveals** problems. It does not fix them, and it does not prove that controls work.
How it works	**Procedural-level** audits (e.g. reviewing internal controls) are often manual. **Architectural-level** audits often use **audit tools**. The definition still says "manual examination", so tools support the audit rather than replace it. **The scope of an audit is much larger than that of testing.** It covers procedures, policies and controls that are **hard to test directly**. Testing concentrates on the **technologies** that support security (firewall configuration, authentication and encryption, user rights). **Neither** audits nor tests guarantee finding every vulnerability. **Typical findings:** weak physical security (dumpster diving of printed customer reports), weak password maintenance (PasswordA/PasswordB alternation), excessive user rights and open file shares, weak server-level security, **vendor security updates not applied**, weak intrusion detection, and no breach-response plan.
Example	An auditor reviews patch records and finds the database servers are six months behind on vendor updates. That is an **audit finding** (it reveals the gap). A tester then runs an exploit for one of the missing patches in the test environment and gains access. That is a **test result** (it proves the gap matters).
Exam angle	Official Q1: "a **purpose** of a security audit?" → **to reveal insufficient vendor patch updates.** Options whose verb is **prevent, halt, force or require** describe **controls**, not audits. **Audit finds; test proves.**
Don't confuse	Audit, test, review and risk assessment have different verbs. **Review** describes (on paper). **Audit** identifies and evaluates. **Test** proves or disproves. **Risk assessment** values and prioritizes (Section 3, table 3.3).

The five pillars of security auditing	
In plain words	An auditor looks at security as **five capabilities** the organization must have: know your risks, make attacks hard, notice attacks, respond fast, and recover without repeating the mistake.

The five pillars of security auditing	
How it works	**Assessment**: threats, key assets, policies, and **management's tolerance for risk**. It is repeated regularly, not done once, which also shows whether policies are **still relevant**. **Prevention**: administrative, operational and technical controls, plus **awareness**. Stopping everything is unrealistic, but layered defenses make attacks much harder. **Detection**: without it you **do not even know** whether you have been compromised. Early detection allows a proper reaction. **Reaction**: **the speed and efficiency of incident response is a key indicator** of how effective the organization's security is. **Recovery**: find **what happened** so the restore does **not recreate the same vulnerability**. Recovery **does not end with restoring the system**. It includes **root cause analysis** and a plan to **prevent similar incidents**.
Example	After ransomware: restoring from backup alone is incomplete recovery. If the unpatched VPN appliance that let the attackers in is restored as it was, the attack will repeat. Root cause analysis → patch it and add MFA → then restore.
Exam angle	"Key indicator of security effectiveness" → **reaction** (speed of incident response). "Root cause analysis" → **recovery**. "Management's tolerance for risk" → **assessment**.
Don't confuse	**Reaction** is about **speed of response**. **Recovery** is about **restoring without recreating the weakness**. The two are often swapped in distractors.

People, process and technology, and why accepting a known risk has a price	
In plain words	Almost every security incident can be traced to a weakness in **people** (skills, attitude, not following rules), **process** (missing, outdated or inconsistent procedures) or **technology** (equipment and software, including technology used wrongly). Neglect one corner of this "iron triangle" and the whole effort suffers.
How it works	**People**: policies are useless if people ignore them. The remedies are **awareness training** or **penalties for noncompliance**. **Process**: to be effective, processes must be **defined, up to date, consistent, and follow best practice**. **Technology**: it makes repetitive work faster and more accurate, and some controls (password enforcement) are impossible without it. But **technology used incorrectly helps people make mistakes faster**. The only way to be sure a defense works is to **test it from an attacker's perspective** (ethical hacking, penetration testing).
Example	The syllabus's tax-agency case: an audit finds that criminals can file fraudulent returns, **testing confirms it**, and the risk is rated **critical**. The agency decides to wait a year. Taxpayers who followed every procedure are defrauded, and the agency is **liable**, because it **knew** about the defect.
Exam angle	If a scenario describes a **confirmed, critical** risk whose fix is **deferred**, the consequence the syllabus wants is **liability** for the organization.
Don't confuse	Testing a risk does not reduce it. **Mitigation** does. Once testing has confirmed a risk, the organization can no longer claim it did not know.

2.6 Fuzzy points clarified

Places where the wording is easy to misread

"Risk assessment" has two meanings. It is the whole NIST process (prepare, conduct, communicate), and it is also the narrower step that **assigns a value** to identified risks (§1.3.2). Read the stem to see which is meant.

The static/dynamic labels on auditor tasks are partly interpretation. The syllabus only says some tasks are static and others, **such as observing processes in action**, are dynamic. Witnessing is clearly dynamic, and reviewing documents is clearly static. The

other labels in Section 1's table are this guide's reading, and they are not examined as such.

"Manual" audit vs audit tools. The syllabus defines an audit as a **manual examination**, and it also says architectural-level audits often use tools. Both statements are true: tools support the auditor's judgement.

"Repudiation" in §5.3.1 means **non-repudiation** (being unable to deny an action). Information assurance in Chapter 2 lists non-repudiation correctly.

The risk-matrix orientation. In this guide, rows are **impact** and columns are **likelihood**. If you redraw it the other way round, the cell values move. Learn the reading "**medium likelihood × high impact = high**", not a cell position.

Five NIST factors vs four conducting steps. The factors are threat, vulnerability, predisposing condition, impact and likelihood. The syllabus groups predisposing conditions **with** vulnerabilities, which is why the conducting sequence has one step fewer.

2.7 Chapter 1 keyword glossary

Keyword	Working definition for the exam
data privacy	Protection of personal and sensitive data from unauthorized disclosure — the subject of the 0–9 scoring example and of the Electronic Monitoring and Privacy policy.
ethical hacker	Someone who tests a system **from an attacker perspective with authorization** — the syllabus equates this with **penetration testing**.
information security	Protection of information and systems against loss of **confidentiality, integrity and availability**.
penetration testing	Testing **from an attacker perspective** to know whether a defense is **working and effective** — the only way to know for sure.
risk assessment	The activity that **assigns a value** to identified risks (impact and likelihood); also the overall NIST process.
risk exposure	**Potential impact or loss × likelihood** of the loss occurring.
risk mitigation	Actions to reduce risk, prioritised by severity — **the higher the severity, the more immediate the response**.
security attack	An attempt to gain unauthorized access to, or use of, a system, service, resource or information.
security audit	**Manual examination and evaluation** that identifies weaknesses in security processes and infrastructure.
security policy	A high-level document describing the principles, approach and major objectives of the organization regarding security; **based on a risk assessment**.
security procedure	**Steps** to implement a specific policy or control, or to respond to a specific incident.
security risk	A risk associated with a security weakness — loss of confidentiality, integrity or availability.

Section 3 — Tables and Summaries

3.1 The chapter on one page

Topic	What to remember	LO
Risk assessment role	Source for planning and design · prioritization by exposure · business alignment · snapshot · checklist + many people	AS-1.1.1
Assets	Five questions: which · how valuable · where · accessed how · secured how	AS-1.1.2
Risk assessment technique	External stakeholders · NIST prepare / conduct / communicate · current **and future** threats	AS-1.1.3
Policies	18 example policies · data classification (5 levels) · procedures = steps	AS-1.2.1
Policy analysis	Objectives + criteria first · checklist · auditor tasks · controls (3 types × 4 functions) · **test results prove effectiveness**	AS-1.2.2
Audit purpose	Manual examination identifying weaknesses · 5 pillars · typical findings · **audit identifies, test proves**	AS-1.3.1

3.2 Behaviour → policy lookup

If the stem mentions...	...the policy is
A user adding a home router or hot spot to the office network	**Network Access**
Rights “in excess of what is needed” for a task	**Minimum Access**
VPN rules for contractors working from home	**Remote Access**
Gambling sites, non-business browsing	**Internet Access**
Leavers’ accounts still active; periodic account review	**User Account Management**
Who decides that a sales report is “confidential”	**Data Classification** (the creating business area)
An unapproved change to a firewall rule; rollback	**Configuration and Change Management**
Default services left running on a server; baseline configuration	**Server Security**
Lost phone; cable locks; encrypted laptop	**Mobile Devices**
Visitor Wi-Fi code after signing the AUP	**Guest Access**
Badge access to the server room; fire; devices carried out	**Physical Security**
“Remember password” in the browser; emailed passwords	**Password Policy**
USB drives restricted	**Malware Protection**
Who talks to the press and police after a breach	**Incident Response**
Auditors requesting log data and traffic records	**Audit Policy**
Installing unapproved software	**Software Licensing**
Monitoring employee email and social media	**Electronic Monitoring and Privacy**

3.3 Audit versus test versus policy review

Activity	Verb	Nature	Output
Policy and procedure review	Describe	Static	Gaps on paper; adequacy against criteria
Security audit	Identify / evaluate	Mostly manual; static + witnessing	Deficiencies and areas to test; recommendations
Security test	**Prove / disprove**	Dynamic, attacker perspective	**Evidence of effectiveness** in practice

Activity	Verb	Nature	Output
Risk assessment	Value / prioritise	Analytic, periodic	Severity per risk → test priority

3.4 Control matrix (fill one control in each cell to self-test)

	Preventive	Detective	Corrective	Recovery
Administrative	Acceptable use policy, two-person approval	Audit of user accounts	Disciplinary action, retraining	Incident response plan
Technical	Firewall, authentication, encryption	IDS, log analysis	Patching, quarantine	Backup restore
Physical	Locks, badge access	CCTV, guards	Repair of broken locks	Alternate site

Table 3.4 examples are illustrative, not syllabus text; the syllabus defines only the three types and four functions and the rule that controls from each category are needed.

3.5 Five pillars of auditing — one line each

Pillar	Question it answers
Assessment	What threats, assets, policies and risk tolerance do we have — **still relevant**?
Prevention	How hard have we made an attack (people, process, technology)?
Detection	Would we **know** if we were compromised?
Reaction	How **fast** do we respond? (**key indicator** of security effectiveness)
Recovery	Can we restore **without recreating the vulnerability**, and did we do **root cause analysis**?

Reproduce from memory before moving on

Table 3.2 (behaviour → policy) and the **data-classification ladder** carry the guaranteed AS-1.2.1 mark.
The rule "test results prove effectiveness" carries the guaranteed AS-1.2.2 K4 mark.
The five asset questions and **the NIST conduct sequence** carry the floating K4 mark (AS-1.1.2 / 1.1.3).

Section 4 — Demo Questions with Answers

*Questions 1–4 are the **official ISTQB CTAL-SEC Sample Exam questions for Chapter 1** — #1 to #4 — with their official correct answers and rationale. The GA sample exam removed the learning-objective tags; the LO shown is inferred from question order and point value, and matches the Exam Structure Table. Questions 5–22 are derived strictly from the syllabus text in the same style. Correct options are marked ✔ — cover the green box and self-test first.*

Part A — The 4 official Chapter 1 questions

Q1. OFFICIAL · Sample Exam #1 (1 pt)

Which of the following is a purpose of a security audit?

a) To prevent users from using simple passwords

b) To reveal insufficient patch updates provided by the vendor ✔

c) To halt unauthorized intruders from accessing the system

d) To require users to change their password after a predetermined set of days

Correct answer: b | LO: AS-1.3.1 (K2) | Syllabus §1.3.1

Why: (b) — official rationale: **keeping the patch updates current on the system is one of the purposes of a security audit.** The others **are good practices, but not the purpose of the security audit**. Syllabus §1.3.1 lists **inadequate application of vendor security updates** among the items an audit might detect. Notice the verbs: an audit **reveals**; (a) prevents, (c) halts and (d) requires — those are controls, not audits.

Q2. OFFICIAL · Sample Exam #2 (3 pts)

You are responsible for ensuring that new vendors brought on externally for the project are fully compliant with government mandated guidelines as part of your risk assessment. On which stakeholders should you primarily focus to ensure these outside vendors continue to comply?

a) Customers, users, and vendors to ensure there is good communication between them

b) Public users and vendors who will follow the law as it applies to the source of information

c) Federal and local agencies that communicate guidelines to follow ✔

d) Both internal and external sources that will use the information for further analyzing the risk

Correct answer: c | LO: AS-1.1.3 (K4) | Syllabus §1.1.3

Why: (c) — official rationale: **this is the source of the guidelines. The guidelines may change so it's important to keep the communications channels open with these folks.** (a), (b) and (d) all need to be informed, **but the information needs to come from the federal and local agencies**. Syllabus §1.1.3: **regulatory agencies** are included in the risk assessment because they are **necessary for ensuring compliance with applicable laws**. (a) is the customers-and-users row (good communication), (b) is the public-and-society row.

Q3. OFFICIAL · Sample Exam #3 (1 pt)

Which of the following is a consequence of a policy that minimizes access to a system or device to acceptable levels?

a) More devices are added to mitigate the impact

b) Proper controls of self-provisioning devices such as routers are prohibited

c) Devices that do not conform are removed from the wireless network ✔

d) Access to the VPN is severely restricted

Correct answer: c | LO: AS-1.2.1 (K2) | Syllabus §1.2.1

Why: (c) — official rationale: **when this policy is implemented, non-conforming devices will be removed until they conform.** (a) is **not an expected result**. (b) is wrong because **these controls will be encouraged**. (d) is wrong because **access will be controlled, not severely limited**. Syllabus §1.2.1: the network access policy **often prohibits users from adding unauthorized devices such as routers and hot spots**; minimum access prevents rights **in excess of what is needed** — a control, not a severe restriction.

Q4. OFFICIAL · Sample Exam #4 (3 pts)

Your role as the Security Administrator is to help your organization understand the effectiveness of security policies and procedures across the enterprise. You will report your effectiveness findings to Senior Management after your analysis has been completed. Which of the following is the optimum strategy to accomplish this?

a) Implement a static analysis evaluation independently for both policies and procedures

b) Analyze the results from a security test to validate effectiveness ✔

c) Evaluate security test results that focus on current threats and attacks

d) Evaluate the static test results for new and emerging software threats

Correct answer: b | LO: AS-1.2.2 (K4) | Syllabus §1.2.2

Why: (b) — official rationale: **you should analyze the results of a security test to see if the policies and procedures have been followed and are effective.** (a) is wrong because **the static analysis should be over the code, if anything**. (c) is wrong because **the focus shouldn't just be on current threats and attacks, but also on configurations, etc.** (d) is wrong because **the focus is not just on the emerging threats**. Syllabus §1.2.2: tests **focus on the risk that a security policy may be in place, may be followed, but is not effective**.

Part B — 18 additional syllabus-derived questions

*The K-level in each question's label is the level of the **learning objective** it practises, not of the question itself. Some Part B items are quick recall checks on a K3 or K4 objective. Use them to learn the facts, and use the scenario items (and Part A) to practise the reasoning the real K3/K4 questions need.*

Q5. Derived from syllabus

Why should security tests be prioritized using the results of a security risk assessment?

a) So that the highest test rigor and coverage are focused on the areas with the greatest risk exposure, aligning testing with business security objectives ✔

b) So that every asset receives the same depth of testing regardless of its value

c) Because a risk assessment remains valid for the lifetime of the system and need not be repeated

d) Because it removes the need to involve stakeholders in defining security test objectives

Correct answer: a | LO: AS-1.1.1 (K2) | Syllabus §1.1.1

Why: (a) is the syllabus wording: prioritizing by the assessment focuses **the highest level of test rigor and coverage on the areas with the greatest risk exposure**, and **the tests become aligned with business security objectives**. (b) contradicts prioritization. (c) is wrong: an assessment is **only a snapshot** and should be repeated at regular intervals. (d) is wrong: alignment only happens if the assessment reflects **the impacted stakeholders**.

Q6. Derived from syllabus

A team fears its security risk assessment has missed important risks because several participants had little security knowledge. Which TWO measures does the syllabus recommend? (Choose the option that names both.)

a) Increase the number of penetration tests and shorten the release cycle

b) Replace the assessment with an external audit and accept its findings

c) Limit participation to security specialists and remove business representatives

d) Use an established security risk assessment methodology as a checklist, and get input from multiple people ✔

Correct answer: d | LO: AS-1.1.1 (K2) | Syllabus §1.1.1

Why: (d) — the syllabus: **ways to deal with the possibility of missing or incomplete risk information include using an established security risk assessment methodology as a checklist and getting input from multiple people** (NIST 800-30 is the example methodology). (c) inverts the advice to **solicit input from a variety of people**. (a) and (b) do not address the knowledge gap.

Q7. Derived from syllabus

An organization last performed a security risk assessment two years ago, before moving its customer portal to the cloud. Which statement best reflects the syllabus?

a) The assessment is still valid because risk assessments describe stable organizational properties

b) The assessment should be repeated: it is only a snapshot, new threats emerge daily, and the interval should reflect the degree of change ✔

c) The assessment only needs to be repeated if a security breach has occurred

d) The assessment should be replaced by continuous penetration testing

Correct answer: b | LO: AS-1.1.1 (K2) | Syllabus §1.1.1

Why: (b). The syllabus states that **any risk assessment is only a snapshot at a given point in time**, that **security risks change continually ... since new threats emerge daily**, and that assessments **should be performed at regular intervals** — typically **three to six months** or **annually**, depending on **the degree of change** the organization experiences. A cloud migration is exactly such a change.

Q8. Derived from syllabus

A design consultancy keeps client drawings on a file server, prints large-format proofs that are left on studio tables, and couriers final designs to clients on encrypted USB drives. Staff also work from home over a VPN. The managing partner asks you which information is needed to assess the level of security required for the client drawings.

Which set of information best supports that assessment?

a) The number of employees and the brand of the file server

b) The cost of the encryption software licences and the VPN bandwidth

c) The drawings' value (e.g. to a competitor, cost to recreate, fines for loss), where they exist in digital and physical form, how they are accessed (VPN, USB, print) and how each copy is secured ✔

d) Only the value of the drawings, since value alone determines the level of security needed

Correct answer: c | LO: AS-1.1.2 (K4) | Syllabus §1.1.2

Why: (c) walks the syllabus's asset questions: **how valuable** (value to a competitor, time and effort to recreate, fines and penalties), **where located** — including **non-digital copies** such as printed proofs, **how accessed** (VPN, **physical data stores passed person to person**) and **how secured** (encryption — **who has the keys**). (d) stops at value; the syllabus says the asset may exist **both in digital and physical format** and both must be considered. (a) and (b) are not asset-security data.

Q9. Derived from syllabus

Which of the following is NOT listed by the syllabus as a method for determining the value of a digital asset?

a) The number of times the asset has been backed up ✔

b) The future revenue to be generated by the asset

c) The time and effort needed to recreate the asset

d) Fines and penalties for not being able to produce the information when needed, e.g. for an audit

Correct answer: a | LO: AS-1.1.2 (K4) | Syllabus §1.1.2

Why: (a). The syllabus lists: **future revenue · value to a competitor · time and effort to recreate · fines and penalties for not producing the information when needed (audit or lawsuit) · fines and penalties for the loss of customer data**. Backup frequency is a protection measure, not a value method.

Q10. Derived from syllabus

Which of the following is an example of a physical or intangible asset given by the syllabus?

a) Tax statements

b) Company reputation and trust ✔

c) Financial spreadsheets

d) Employee records

Correct answer: b | LO: AS-1.1.2 (K4) | Syllabus §1.1.2

Why: (b). The syllabus's physical or intangible examples are **physical prototypes of new devices under development · the ability to deliver services · company reputation and trust**. (a), (c) and (d) are on the list of **high-value sensitive information**.

Q11. Derived from syllabus

A risk analyst lists these tasks for conducting a security risk assessment: (1) determine adverse impacts, (2) identify threat sources, (3) identify vulnerabilities and predisposing conditions, (4) determine likelihood, (5) identify threat events. Which order follows NIST 800-30 as presented in the syllabus?

a) 1, 4, 2, 5, 3

b) 3, 2, 5, 1, 4

c) 2, 3, 5, 4, 1

d) 2, 5, 3, 4, 1 ✔

Correct answer: d | LO: AS-1.1.3 (K4) | Syllabus §1.1.3

Why: (d): threat sources → threat events produced by those sources → vulnerabilities and predisposing conditions → likelihood (that sources initiate events and that events succeed) → adverse impacts. The logic is causal: a source produces an event that exploits a vulnerability; only then can likelihood and impact be judged.

Q12. Derived from syllabus

An online pharmacy is preparing a security risk assessment. The project manager proposes to invite only the internal development team and the security officer, so that the assessment stays "manageable".

What is the most significant weakness of this approach?

a) It omits external stakeholders — customers and users, the public, and regulatory agencies — whose perspectives the syllabus says a security risk assessment should include ✔

b) It includes the security officer, who should be independent of risk assessments

c) It will make the assessment too broad to complete

d) It fails to involve the vendor of the database, who owns the risk

Correct answer: a | LO: AS-1.1.3 (K4) | Syllabus §1.1.3

Why: (a). The syllabus: **a security risk assessment should include the perspectives of external security testing stakeholders — customers and users** (perspective, input, communication), **the public and society** (security as a community responsibility), **regulatory agencies** (compliance with law). A pharmacy is a regulated business handling personal data, so missing regulators and customers is the critical gap.

Q13. Derived from syllabus

Which practice best helps a risk assessment identify FUTURE as well as current security threats?

a) Using only the list of attacks seen in the last twelve months

b) Basing likelihood exclusively on historical evidence for adversarial threats

c) Repeating the assessment regularly and maintaining it throughout the lifecycle with continuous monitoring, because emergent vulnerabilities appear as environments and technologies change ✔

d) Removing predisposing conditions from the risk model to simplify the analysis

Correct answer: c | LO: AS-1.1.3 (K4) | Syllabus §1.1.3, §1.3.2

Why: (c). The syllabus warns of **emergent vulnerabilities** that arise **as missions, environments and technologies change**, notes that **controls degrade in effectiveness over time**, and stresses **maintaining risk assessments during the entire software lifecycle** and **continuous monitoring**. (b) is wrong: adversarial likelihood is based on **intent, capability and targeting**; historical evidence is for **non-adversarial** events.

Q14. Derived from syllabus

A merger and acquisition plan known only to company officers would be classified at which level in the syllabus's example structure?

a) Confidential

b) Private ✔

c) Public

d) Secret

Correct answer: b | LO: AS-1.2.1 (K2) | Syllabus §1.2.1

Why: (b) Private: information **often restricted to officers of the organization** who must be specifically authorized; disclosure could cause **major negative impact such as financial harm**; examples include **R&D information, merger and acquisition plans** and customer card and account data. **Secret** (d) is information **obtained from an external party** that may have **no tangible value for the organization itself**.

Q15. Derived from syllabus

Who is typically responsible for classifying data according to a data classification policy?

a) The business area that creates the data ✔

b) The IT security administrator

c) The external auditor

d) The database administrator

Correct answer: a | LO: AS-1.2.1 (K2) | Syllabus §1.2.1

Why: (a). The syllabus: **typically, the business area that creates the data is responsible for its classification based on a standard classification structure**.

Q16. Derived from syllabus

Which statement best describes the difference between a security policy and a security procedure?

a) A policy is mandatory; a procedure is optional guidance

b) A procedure is approved by senior management; a policy is written by system administrators

c) Policies, standards and guidelines describe the controls that should be in place; a procedure explains how to implement them step by step ✔

d) A procedure is only written after a security incident has occurred

Correct answer: c | LO: AS-1.2.1 (K2) | Syllabus §1.2.1

Why: (c) is the syllabus definition. Procedures specify **the steps to be taken in implementing a specific policy or control, and the steps to be taken in response to a specific security incident** — so (d) is only half the story, and procedures facilitate implementation of policies rather than being optional (a).

Q17. Derived from syllabus

Which policy most directly prohibits downloading and installing unapproved software?

a) Acceptable Use

b) Malware Protection

c) Configuration and Change Management

d) Software Licensing ✔

Correct answer: d | LO: AS-1.2.1 (K2) | Syllabus §1.2.1

Why: (d). The syllabus: under Software Licensing, **downloading and installing unapproved software is a key prohibition often found in this policy**, because violating commercial licences exposes the organization to **fines and legal action**. Malware Protection's example is **restricting USB drives**.

Q18. Derived from syllabus

A bank's password policy requires 8 characters with mixed case and a change every 60 days. Interviews show that staff believe the policy is followed, and an audit of the policy document finds it complete. A security tester then runs a password cracking tool against a copy of the credential store and recovers 40% of passwords within an hour, most of them variants of the season and year.

What is the best conclusion about the effectiveness of the password policy and procedure?

a) The policy is effective, because it is documented and followed

b) The policy is in place and followed but is not effective in protecting the asset; the test result shows it falls short of its goals ✔

c) The policy is ineffective only because the interviews were not sufficiently detailed

d) No conclusion is possible until a second static review is performed

Correct answer: b | LO: AS-1.2.2 (K4) | Syllabus §1.2.2

Why: (b) is the precise risk the syllabus says security tests target: **a security policy may be in place, may be followed, but is not effective in protecting assets**. The syllabus's own example: **a password policy may seem reasonable and effective on paper, but when a password cracking tool is used, the procedure may fall short of its goals.** (a) and (d) rely on static evidence only.

Q19. Derived from syllabus

Before evaluating a set of security policies and procedures, what should be defined FIRST?

a) The objective(s) of the evaluation and the criteria by which to judge adequacy ✔

b) The penetration testing tools to be purchased

c) The list of employees to be disciplined for non-compliance

d) The remediation budget for any weaknesses found

Correct answer: a | LO: AS-1.2.2 (K4) | Syllabus §1.2.2

Why: (a). The syllabus: **before evaluating a set of security policies and procedures it is important to determine the objective(s) of the evaluation and define a set of criteria by which to judge the adequacy** — criteria may come from **COBIT, ISO 27001 or PCI**. Resources, measures, location and a checklist follow.

Q20. Derived from syllabus

An organization has a detailed set of technical security controls (firewalls, IDS, encryption) but no written procedures, no awareness training, and no locks on its server room. Based on the syllabus's view of controls, what is the main weakness?

a) There are too many technical controls, which will reduce usability

b) Detective controls should always be replaced by preventive ones

c) Controls are provided from only one category; in general controls must be provided from each category (administrative, technical, physical) to protect an asset effectively ✔

d) Technical controls cannot be tested and therefore cannot be relied upon

Correct answer: c | LO: AS-1.2.2 (K4) | Syllabus §1.2.2

Why: (c). The main control types are **administrative, technical and physical**; within each, controls are **preventive, detective, corrective or recovery**. **These control types work together, and in general, controls must be provided from each category to effectively protect an asset.**

Q21. Derived from syllabus

How does the scope of a security audit compare with that of security testing?

a) They have the same scope but audits are performed by external parties

b) Auditing has a much larger scope and covers procedures, policies and controls that are difficult to test directly; testing is more involved with the technologies supporting security ✔

c) Testing has a larger scope because it includes penetration testing

d) Audits only examine physical security, while testing covers all logical controls

Correct answer: b | LO: AS-1.3.1 (K2) | Syllabus §1.3

Why: (b) — syllabus §1.3: **the scope of security auditing is much larger than security testing. Security auditing often investigates areas such as procedures, policies and controls that are difficult to test in a direct way. Security testing is more involved with the technologies to support security, such as firewall configuration, correct application of authentication and encryption, and application of user rights.**

Q22. Derived from syllabus

Which of the five pillars of security auditing is described as including root cause analysis to determine which process, procedure and technology changes reduce the likelihood of the same vulnerability in future?

a) Assessment

b) Detection

c) Reaction

d) Recovery ✔

Correct answer: d | LO: AS-1.3.1 (K2) | Syllabus §1.3

Why: (d) Recovery — it **starts with determining what occurred** so systems are recovered **without recreating the same vulnerability**, and **does not end with restoring the system**: **root cause analysis** follows. Reaction (c) is about **speed and efficiency of incident response** — the **key indicator** of security effectiveness.

Most Important Questions From This Chapter

*Ranking rationale: the Exam Structure Table guarantees one question each on **AS-1.2.1 (K2)** and **AS-1.2.2 (K4)**, plus one K2 from {1.1.1, 1.3.1} and one K4 from {1.1.2, 1.1.3}. The two K4 items are **6 of the chapter's 8 points**.*

Rank	Topic / question focus	LO	Why it matters
1	Test results prove policy effectiveness — Q4, Q18, Q19, Q20	AS-1.2.2	**Guaranteed 3-point question.** Static review alone is always the distractor.
2	External stakeholders and the NIST task sequence — Q2, Q11, Q12, Q13	AS-1.1.3	**Half of the floating 3-point K4.** Compliance → regulatory agencies.
3	Five asset questions; digital and physical — Q8, Q9, Q10	AS-1.1.2	**Other half of the floating K4.** Value alone is never enough.
4	Policy recognition and data classification — Q3, Q14, Q15, Q16, Q17	AS-1.2.1	**Guaranteed 1-point question.** Table 3.2 decides it.
5	Audit purpose, scope and pillars — Q1, Q21, Q22	AS-1.3.1	Shares a K2 slot with AS-1.1.1; **audit reveals, controls prevent**.
6	Risk assessment as snapshot and prioritizer — Q5, Q6, Q7	AS-1.1.1	Shares a K2 slot; also the conceptual base for Chapters 2 and 3.

Section 5 — Exam Tricks

5.1 Frequently tested topics (evidence-based)

The Exam Structure Table gives Chapter 1 **four questions worth eight points**. Two are fixed (**AS-1.2.1**, **AS-1.2.2**); two are drawn from pairs. The official Sample Exam drew **AS-1.3.1** and **AS-1.1.3**.

LO	K	Qs	Pts	Sample #	Format used officially
AS-1.1.1 / 1.3.1	K2	1	1	#1	"Which of the following is **a purpose of a security audit**?" — one audit outcome among three controls
AS-1.1.2 / 1.1.3	**K4**	1	**3**	#2	Scenario + "**on which stakeholders should you primarily focus**?" — compliance with government guidelines
AS-1.2.1	K2	1	1	#3	"Which is **a consequence of** a policy that minimizes access…?"
AS-1.2.2	**K4**	1	**3**	#4	Scenario + "**optimum strategy**" to determine effectiveness of policies and procedures
Chapter 1 total	—	**4**	**8**	**#1–#4**	**10% of the points; two 3-point items carry three-quarters of the chapter**

The arithmetic before you sit the exam

CT-SEC is **45 questions worth 80 points in 120 minutes**; pass = **52 points (65%)**. Points per question: **K2 = 1, K3 = 2, K4 = 3**. There are **20 K2, 15 K3 and 10 K4** questions — so **K2 recall is only 20 of 80 points**. Even a perfect K2 score leaves you needing **32 of the 60 scenario points**. Chapter 1's two K4 items are worth as much as **six K2 questions**.

5.2 Common distractors observed

- **Controls dressed up as audit purposes** — "prevent simple passwords", "halt intruders", "require password changes". An audit **reveals and evaluates**; it does not enforce.
- **Static review offered as proof of effectiveness** — "a static analysis evaluation of policies and procedures". The syllabus: effectiveness is shown by **security test results**.
- **Half-scoped testing** — "security test results that focus on current threats" or "emerging threats" only. The official rationale rejects both: **configurations, etc.** must also be covered.
- **The right stakeholder group, but the wrong reason** — customers for "good communication" when the stem is about **legal compliance** (→ regulators).
- **Value-only asset assessment** — the level of security needed also depends on **where** the asset is, **how** it is accessed and **how** it is secured.
- **Treating a risk assessment as permanent** — it is a **snapshot**.
- **Restriction confused with control** — minimum access means access is **controlled**, not **severely limited**; controls over self-provisioned devices are **encouraged**, not prohibited.

5.3 Keyword recognition (map words → answers)

If the stem says…	Think…
"government mandated", "law", "regulation", "compliance"	**Regulatory agencies** — the source of the guidelines
"effectiveness of policies and procedures"	**Analyze security test results**
"in place and followed, but…"	**Not effective** — only a test reveals it
"purpose of an audit", "audit finding"	**Reveal / identify** weaknesses — e.g. **vendor security updates not applied**
"snapshot", "point in time"	Repeat risk assessments **regularly** (3–6 months to annually)

If the stem says...	Think...
“missed risks”, “incomplete information”	**Methodology as checklist + many participants**
“impact × likelihood”	**Risk exposure**
“medium likelihood, high impact”	**High** severity (syllabus matrix)
“two people must approve”	A **control** (administrative, preventive)
“dumpster diving”	**Inadequate physical security** audit finding
“PasswordA / PasswordB”	**Inadequate password maintenance** — password history in audit tools
“people, process, technology”	**Iron triangle**; every incident traces back to one
“only way to know for sure”	**Test from an attacker perspective** — ethical hacking / penetration testing

5.4 Typical traps

- **Confidential vs private vs secret.** Confidential is the **default** for internal documents. Private is **officers only** (M&A, card data). Secret is **external-party** information that may have **no tangible value to the organization itself** — so it is **not a trade secret**.
- **Threat vs threat source vs vulnerability.** A **source** (hostile attacker, human error, structural failure, disaster) causes a **threat event**, which exploits a **vulnerability** (a weakness in a system, procedure, control or implementation).
- **Adversarial vs non-adversarial likelihood.** Adversarial → **intent, capability, targeting**. Non-adversarial → **historical evidence, empirical data**.
- **Business vs technical impact.** Use **business impact** when available; technical impact is **the next best thing**.
- **Audit scope.** Larger than testing, not smaller; audits cover what is **hard to test directly**.
- **Recovery vs reaction.** Speed of incident response = **reaction** (the key effectiveness indicator). Root cause analysis = **recovery**.

5.5 How to eliminate wrong answers

1. **Check the verb.** Audits reveal; controls prevent; tests prove; assessments value and prioritise. An option with the wrong verb for the activity is wrong.
2. **Check the evidence.** If the stem asks about effectiveness, strike every option that relies only on documents, interviews or static review.
3. **Check the scope.** Strike options limited to “current” or “emerging” threats when the syllabus wants both — and configurations too.
4. **Check the source.** For compliance, the right stakeholder is the one who **issues** the rules.
5. **Check completeness.** For asset questions, value + location + access + protection beats any single factor.

5.6 Scenario-solving shortcuts

Scenario shape	Shortcut
“Report effectiveness to senior management”	Pick the option that **analyses test results**.
“Ensure vendors keep complying with government guidelines”	Pick the option naming the **agencies that issue** the guidelines.
“What data do you need to assess the security level of asset X?”	Pick the option that answers **value, location, access, protection**.
“Risk assessment missed something”	Pick **checklist methodology + broader participation**, or **repeat the assessment**.
“Audit found X; what next?”	**Evaluate risk and put an improvement plan in place**; then test to prove or disprove.
“Known critical risk deferred”	The organization carries **liability** (tax-agency example).

5.7 Common candidate mistakes

- Treating Chapter 1 as "intro" and skipping it — it holds **two 3-point questions**.
- Memorising all eighteen policies word-for-word instead of learning the **identifying phrase** of each (Table 3.2).
- Forgetting that assets can be **physical or intangible** (reputation, ability to deliver services).
- Believing an audit **guarantees** finding all vulnerabilities — neither audits nor tests do.
- Reading the risk matrix with the axes swapped. Rows are **impact**, columns are **likelihood** in this guide's rendering; the syllabus reading is **medium likelihood × high impact = high**.

5.8 Mnemonics that carry the whole chapter

Mnemonic	Expands to
W-H-W-H-H (Which, How valuable, Where, How accessed, How secured)	The five asset questions
S-E-V-L-I ("Seven lives")	NIST conduct order: **S**ources → **E**vents → **V**ulnerabilities → **L**ikelihood → **I**mpact
A-P-D-R-R ("A Pretty Dull Risk Report")	Five audit pillars: **A**ssessment, **P**revention, **D**etection, **R**eaction, **R**ecovery
ATP × PDCR	Control types **A**dministrative, **T**echnical, **P**hysical × functions **P**reventive, **D**etective, **C**orrective, **R**ecovery
P-C-HC-P-S ("Please Call Him Privately, Sir")	Data classification: **P**ublic, **C**onfidential, **H**ighly **C**onfidential, **P**rivate, **S**ecret
"Audit finds, test proves"	The auditing–testing relationship in four words

5.9 Chapter 1 mind map

Branch	Leaves
Security risk	Impact × likelihood · CIA loss · NIST 800-30 · OWASP risk rating · snapshot · checklist + many people
Assets	Information · physical · intangible · value methods · location · access · protection
Risk assessment	External stakeholders · prepare / conduct / communicate · threats, vulnerabilities, impact, likelihood, predisposing conditions · 0–9 scoring · matrix
Policies	18 examples · data classification · procedures (how) · controls ATP × PDCR
Policy analysis	Objectives + criteria · checklist · auditor tasks (static + dynamic) · test results prove effectiveness
Auditing	Manual examination · larger scope than testing · 5 pillars · typical findings · people/process/technology · attacker perspective

Section 6 — Revision Notes

6.1 One-page chapter summary

Security testing starts from security risk. A security risk assessment tells you which assets are at risk and how much; it is the basis for planning, designing and prioritizing tests, and aligns them with business objectives — provided it reflects real threats, stakeholders and assets. It is a snapshot, so repeat it; and it misses things, so use a methodology checklist and many participants.

Assets are information, physical items and intangibles. Assess **which** matter, **how valuable** they are, **where** they live, **how** they are accessed and **how** they are protected. **Risk assessment technique** (NIST 800-30): prepare, conduct (sources → events → vulnerabilities → likelihood → impact), communicate; include customers, the public and regulators.

Policies rest on the risk assessment; **procedures** implement them step by step; **controls** (administrative, technical, physical × preventive, detective, corrective, recovery) enforce them. **Effectiveness is proven by security test results**, not by paperwork.

Audits manually examine and evaluate, with a larger scope than testing, along five pillars. **Audit finds; test proves.** Risk exposure = impact × likelihood; severity drives the urgency of mitigation.

6.2 Key definitions to memorize

Term	Definition
Risk	Function of adverse impact and likelihood of occurrence
Information security risk	Risk from loss of confidentiality, integrity or availability
Risk exposure	Impact × likelihood
Threat	Circumstance or event with potential adverse impact via an information system
Vulnerability	Weakness in a system, procedure, internal control or implementation that a threat source could exploit
Security control	Safeguard or countermeasure to avoid, counteract or minimize loss
Security procedure	Steps to implement a policy or control, or respond to an incident
Security audit	Manual examination and evaluation identifying weaknesses in security processes and infrastructure

6.3 High-priority concepts (study first)

6. **Test results prove policy effectiveness** (AS-1.2.2 — guaranteed 3 points).
7. **External stakeholders and NIST process** (AS-1.1.3 — possible 3 points).
8. **Five asset questions** (AS-1.1.2 — possible 3 points).
9. **Policy recognition and data classification** (AS-1.2.1 — guaranteed 1 point).
10. **Audit purpose and pillars** (AS-1.3.1 — possible 1 point).

6.4 Last-minute revision sheet

If you read nothing else

Risk = impact × likelihood. Info-sec risk = loss of C, I or A. Assessment = snapshot → repeat; checklist + many people.
Assets: which · how valuable · where · accessed how · secured how. Physical/intangible: prototypes, service delivery, reputation.
External stakeholders: customers/users (communication) · public (community) · **regulators (law)**.
NIST conduct: sources → events → vulnerabilities → likelihood → impact.
Policy basis = risk assessment. Procedure = how. Controls: ATP × PDCR, from each category.
Effectiveness = security test results. In place + followed ≠ effective.
Audit = manual examination; scope larger than testing; pillars APDRR; reveals e.g. missing vendor updates.
Matrix: medium likelihood × high impact = high. Business impact > technical impact.

6.5 Memorization checklist

✓	I can…
☐	state the role of a risk assessment in planning, design, prioritization and alignment
☐	list the five asset questions and give two examples for each
☐	name the three external stakeholder groups and why each is included
☐	order the NIST conducting tasks
☐	match at least twelve behaviours to their policy
☐	order the five data classification levels and give one example each
☐	explain why test results, not documents, show policy effectiveness
☐	name the five audit pillars and seven typical audit findings
☐	compute risk exposure and read the syllabus risk matrix

6.6 Exam-day quick review

- Two of the four Chapter 1 questions are **3-point K4s** — read their scenarios slowly.
- **Audit = reveal. Control = prevent. Test = prove.**
- **Compliance question → regulators.**
- **Effectiveness question → test results.**